

**PANEVROPSKI UNIVERZITET APEIRON, BANJA LUKA
FAKULTET INFORMACIONIH TEHNOLOGIJA
PROGRAMIRANJE I SOFTVERSKI INŽENJERING**

„SAJBER KRIMINAL“

**SEMINARSKI RAD IZ PREDMETA
„CYBER PRAVO“**

Kandidat:
Nikolina Bekić
Br. indeksa: 21-22-FIT-IIT1-PRO-240

Mentor:
Doc. dr Boris Kovačić

SADRŽAJ

UVOD	1
1. POJAM I RAZVOJ SAJBER KRIMINALA	2
1.1. Definisanje pojma i osnovne podjele	2
1.2. Akteri i motivi od pojedinaca do organizovanih grupa	2
2. NAJČEŠĆI OBLICI SAJBER KRIMINALA U PRAKSI	5
2.1. Ransomware i digitalna iznuda	5
2.2. Phishing, socijalni inženjering i krađa identiteta	6
2.3. Napadi na dostupnost (botneti i DDoS)	7
3. SUZBIJANJE SAJBER KRIMINALA	9
3.1. Međunarodni pravni okvir i prekogranična saradnja	9
3.2. Digitalni dokazi i digitalna forenzika	10
3.3. Upravljanje rizikom i organizacione mjere zaštite	11
3.4. Edukacija korisnika i kultura bezbjednosti	11
ZAKLJUČAK	13
POPIS SLIKA	14
CITATNI IZVORI	15

UVOD

U savremenom društvu tehnologija je postala neizostavan dio svakodnevnog života. Internet, društvene mreže, elektronsko bankarstvo, online kupovina i različite digitalne platforme omogućili su ljudima bržu komunikaciju, lakši pristup informacijama i jednostavnije obavljanje brojnih obaveza. Međutim, razvoj informacionih tehnologija nije donio samo prednosti, već je otvorio prostor i za nove oblike zloupotreba i kriminalnih aktivnosti. Upravo zbog toga sajber kriminal predstavlja jedan od najvećih bezbjednosnih izazova modernog doba.

Sajber kriminal obuhvata različite vrste krivičnih djela koja se izvršavaju korišćenjem računara, interneta i drugih digitalnih sistema. To mogu biti krađe podataka, prevare putem interneta, hakovanje naloga, širenje zlonamjernih programa, ucjene, krađa identiteta, ali i ozbiljni napadi na kompanije, državne institucije i kritičnu infrastrukturu. Poseban problem predstavlja činjenica da se ovakva djela mogu izvršavati veoma brzo i često anonimno, zbog čega je pronalaženje počinitelaca mnogo složenije nego kod tradicionalnog kriminala.

Razvojem digitalnog društva povećava se i broj korisnika koji svakodnevno ostavljaju svoje podatke na internetu, često bez dovoljno znanja o mogućim rizicima. Mnogi korisnici nisu svjesni koliko ličnih informacija dijele putem društvenih mreža, elektronske pošte ili različitih aplikacija. Upravo zbog toga sajber kriminal ne pogađa samo velike kompanije i institucije, već i obične građane koji mogu postati žrtve internet prevara, krađe identiteta ili zloupotrebe bankovnih podataka.

Dodatni problem predstavlja međunarodni karakter sajber kriminala. Napadi se mogu organizovati iz jedne države, izvršiti preko servera u drugoj, dok se posljedice osjećaju u trećoj zemlji. Zbog toga je borba protiv sajber kriminala veoma zahtjevna i traži saradnju između država, policijskih agencija, pravosudnih organa i stručnjaka iz oblasti informacionih tehnologija. U cilju efikasnijeg suzbijanja ovih djela, veliki značaj imaju međunarodni sporazumi i konvencije koje omogućavaju zajedničko djelovanje i razmjenu informacija.

Pored represivnih mjera, važnu ulogu ima i prevencija. Edukacija korisnika, razvoj bezbjednosne kulture i pravilna zaštita digitalnih sistema predstavljaju ključne korake u smanjenju rizika od sajber napada. Savremeno društvo sve više zavisi od tehnologije, pa samim tim raste i potreba za zaštitom podataka, privatnosti i informacionih sistema.

1. POJAM I RAZVOJ SAJBER KRIMINALA

1.1. Definisanje pojma i osnovne podjele

U praksi se sajber kriminal najčešće povezuje sa krivičnim djelima koja uključuju računare, internet, mreže i digitalne podatke. Ipak, nije svako takvo djelo isto. „Neka krivična djela postoje isključivo zbog tehnologije, dok se kod drugih tehnologija samo koristi kao alat za izvršenje. Zbog toga se često pravi podjela na sajber-zavisna i sajber-omogućena krivična djela“ [1].

„Sajber-zavisna djela su ona koja bez računara i mreža praktično ne bi mogla postojati. Tu spadaju hakovanje sistema, širenje virusa i malvera, kao i DDoS napadi kojima se preopterećuju serveri i onemogućava rad određenih servisa. Sa druge strane, sajber-omogućena djela predstavljaju klasične oblike kriminala koji su internetom dobili mnogo veći domet i brzinu. Primjeri za to su online prevare, krađa identiteta, ucjene, phishing napadi i zloupotreba ličnih podataka“ [1].

„Problem sa definisanjem sajber kriminala jeste to što se tehnologija veoma brzo mijenja. Pojavom novih aplikacija, platformi i online servisa gotovo odmah nastaju i novi načini njihove zloupotrebe. Zbog toga zakonodavstvo često kasni za stvarnim problemima u praksi“ [1]. „Danas se zbog toga ne govori samo o pojedinačnim krivičnim djelima, već i o upravljanju rizicima, zaštiti sistema i preventivnim mjerama koje mogu smanjiti mogućnost napada“ [2].

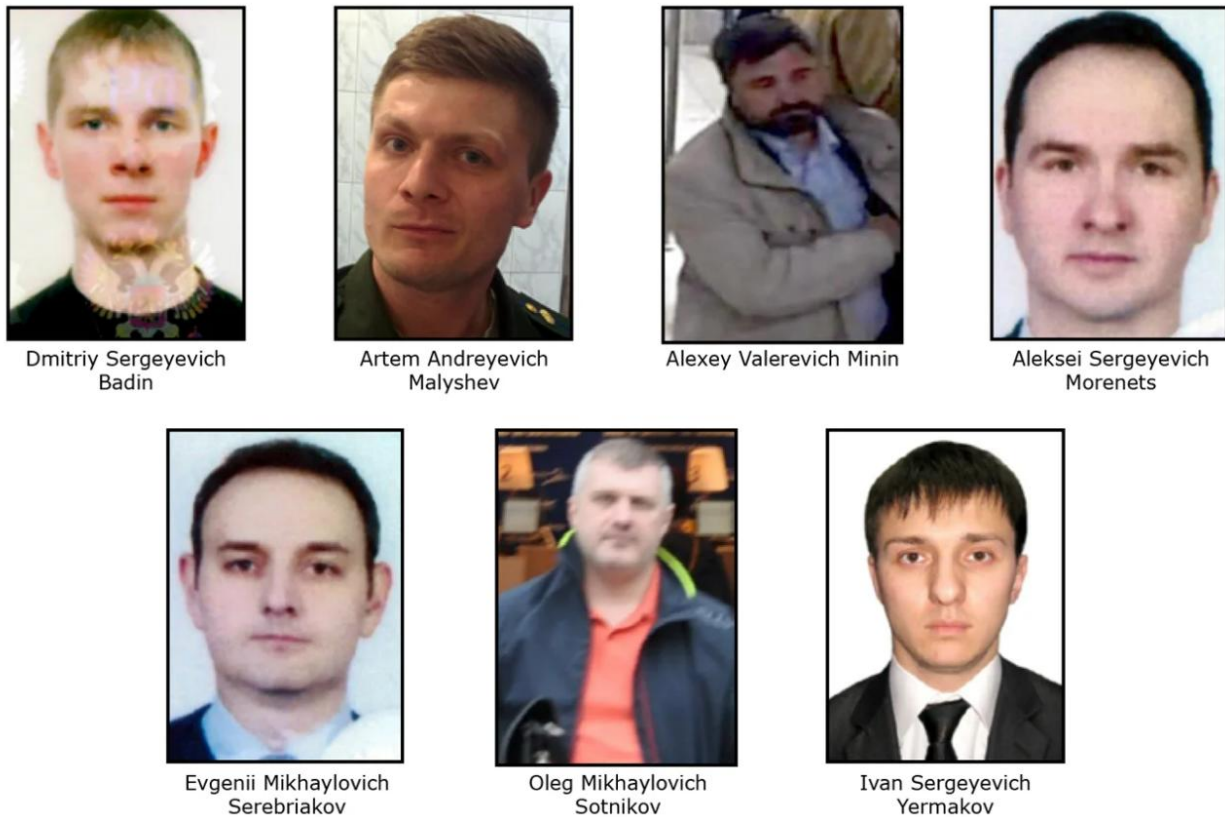
Važno je naglasiti da sajber kriminal nije jedna jedinstvena pojava, već skup različitih oblika kriminalnih aktivnosti koje povezuje digitalno okruženje. Jedan napad često uključuje više različitih elemenata. Na primjer, ransomware napad može obuhvatiti neovlašćen pristup sistemu, krađu podataka, ucjenu žrtve i finansijske prevare. Upravo zbog toga posljedice sajber kriminala mogu biti tehničke, finansijske, ali i pravne, pa organizacije moraju unaprijed planirati način zaštite i reagovanja.

Razvoj sajber kriminala usko je povezan sa razvojem interneta i digitalnih tehnologija. U početku su napadi uglavnom bili vezani za dokazivanje tehničkog znanja i radoznalost pojedinaca, dok su danas mnogo češće motivisani finansijskom koristi. Savremeni sajber kriminal postao je organizovaniji, brži i dostupniji većem broju ljudi zahvaljujući automatizaciji i alatima koji se mogu pronaći ili iznajmiti na ilegalnim online tržištima. Zbog toga se danas često govori o modelu „kriminal kao usluga“, gdje pojedinci ne moraju imati veliko tehničko znanje da bi izvršili napad, već mogu kupiti ili iznajmiti potrebne alate i pristup infrastrukturi.

1.2. Akteri i motivi od pojedinaca do organizovanih grupa

Jedan od glavnih razloga zbog kojih je sajber kriminal teško zaustaviti jeste veliki broj različitih aktera koji učestvuju u njemu. Kada se govori o hakerima, ljudi često zamišljaju jednog pojedinca koji sjedi za računarom i pokušava da „provali“ u neki sistem. Međutim, stvarnost je danas mnogo složenija. „Pored pojedinaca koji djeluju samostalno, postoje i organizovane kriminalne grupe koje funkcionišu gotovo kao prave kompanije. Takve grupe imaju podjelu poslova, svoje programere, ljude koji traže mete, pa čak i osobe koje pregovaraju sa žrtvama tokom ransomware ucjena“ [2].

Savremeni sajber kriminal se sve više razvija kroz takozvani „as-a-service“ model. To znači da se alati za napade mogu kupiti ili iznajmiti na ilegalnim forumima i mrežama. „Na primjer, neko može platiti gotov ransomware ili malver bez potrebe da ga sam pravi. Upravo zbog toga je mnogo lakše uključiti se u sajber kriminal nego ranije, jer nije uvijek potrebno veliko tehničko znanje za izvođenje napada“ [2].



Slika 1 - Potjernica izdata od strane FBI-a u svrhu potjere ruskih državljana koje vezuju za sajber kriminal

„Najčešći motiv za sajber napade jeste finansijska korist. Napadači pokušavaju ukrasti novac, podatke, pristup bankovnim računima ili iznuditi otkup od žrtava. Međutim, nisu svi napadi motivisani samo novcem. Pojedini napadi imaju političku ili ideološku pozadinu, dok se neki povezuju i sa interesima država i međunarodnim sukobima. U takvim situacijama granica između običnog kriminala i političkih ili bezbjednosnih prijetnji postaje veoma nejasna“ [4].

„U posljednjih nekoliko godina sve je više napada koji se ne oslanjaju samo na tehničke greške sistema, već na manipulaciju ljudima. Napadači često pokušavaju doći do korisničkih naloga putem lažnih poruka, lažnih prijava i različitih oblika socijalnog inženjeringa. Cilj je da korisnik sam otkrije lozinku ili omogući pristup sistemu, često bez svijesti da je prevaren“ [4].

„Pored direktnih napadača, u sajber kriminalu važnu ulogu imaju i različiti posrednici. To su osobe ili grupe koje prodaju ukradene podatke i lozinke, održavaju mreže zaraženih računara ili pružaju infrastrukturu koja pomaže sakrivanju identiteta napadača. Iako možda ne učestvuju direktno u napadu, bez njih bi mnoge kriminalne aktivnosti bile mnogo teže izvesti“ [2]. Upravo zbog te podjele poslova i specijalizacije sajber kriminal je postao veoma otporan, pa se nakon gašenja jedne grupe često brzo pojavljuju nove koje nastavljaju iste aktivnosti.

Ne treba zanemariti ni unutrašnje prijetnje unutar organizacija. Ponekad problem nije sofisticiran napad, već greška zaposlenih, loše zaštićene lozinke, neažurirani sistemi ili nepažljivo otvaranje sumnjivih linkova i fajlova. U mnogim slučajevima sajber incidenti nastaju kombinacijom tehničkih slabosti i ljudskih grešaka. Zbog toga zaštita od sajber kriminala ne zavisi samo od tehnologije, već i od edukacije korisnika i dobre organizacije bezbjednosti.

2. NAJČEŠĆI OBLICI SAJBER KRIMINALA U PRAKSI

2.1. Ransomware i digitalna iznuda

„Ransomware je posljednjih godina postao jedan od najpoznatijih i najopasnijih oblika sajber kriminala. Razlog za to je činjenica da ovakvi napadi mogu potpuno zaustaviti rad kompanija, institucija i drugih organizacija. Osnovni princip ransomware napada jeste zaključavanje ili šifrovanje podataka, nakon čega napadači traže novac kako bi omogućili ponovni pristup sistemu. Međutim, današnji napadi su mnogo složeniji nego ranije. U mnogim slučajevima napadači prvo ukradu osjetljive podatke, a tek nakon toga zaključaju sisteme. Na taj način dodatno pritiskaju žrtvu prijetnjama da će objaviti ili prodati ukradene informacije ukoliko otkup ne bude plaćen“ [2], [3].

Ransomware danas nije samo tehnički problem za IT sektor. Kada dođe do napada, posljedice brzo pogađaju cijelu organizaciju. Prekid rada sistema može zaustaviti poslovanje, komunikaciju sa korisnicima i pružanje usluga. „Pored finansijske štete, organizacije često trpe i gubitak povjerenja korisnika, narušavanje reputacije i velike troškove oporavka sistema. Zbog toga se savremeni pristupi sajber bezbjednosti ne zasnivaju samo na pokušaju sprečavanja napada, već i na pripremi za brži oporavak kada do incidenta ipak dođe“ [2].



Slika 2 - Primjer Ransomware iznude u pravom životu

Veliki broj ransomware napada povezan je sa ljudskim greškama i lošom zaštitom sistema. „Napadači često dolaze do pristupa preko ukradenih lozinki, neažuriranih programa, ranjivih web aplikacija ili pogrešno podešenih sistema“ [5]. Dovoljno je da jedan zaposleni otvori sumnjiv fajl

ili klikne na lažni link kako bi napadači dobili pristup mreži organizacije. Nakon toga se napad može veoma brzo proširiti na veliki broj uređaja i servera.

Kada ransomware zahvati sistem, veoma je važno da organizacija ima unaprijed pripremljen plan reagovanja. To uključuje izolaciju zaraženih uređaja, zaštitu preostalih podataka, prikupljanje digitalnih dokaza i vraćanje sistema iz rezervnih kopija. Organizacije koje nemaju plan oporavka često mnogo sporije reaguju, zbog čega su i posljedice ozbiljnije.

Zaštita od ransomware napada uglavnom se zasniva na osnovnim, ali veoma važnim bezbjednosnim mjerama. To podrazumijeva pravljenje rezervnih kopija podataka, korišćenje višefaktorske autentifikacije, redovno ažuriranje sistema, ograničavanje pristupa zaposlenih i podjelu mreže na više segmenata. Iako ove mjere djeluju jednostavno, upravo one u praksi često odlučuju da li će organizacija uspjeti da se odbrani od napada ili će pretrpjeti veliku štetu. U mnogim slučajevima problem nije u tome što su napadači bili posebno sofisticirani, već što sistemi nisu bili dovoljno zaštićeni i održavani.

2.2. Phishing, socijalni inženjering i krađa identiteta

„Phishing i krađa identiteta spadaju među najrasprostranjenije oblike sajber kriminala, prije svega zato što su jednostavni za izvođenje, jeftini i lako se prilagođavaju različitim situacijama. Napadač može poslati veliki broj lažnih poruka uz minimalan trud, a čak i mali procenat uspješnih žrtava može biti dovoljan da napad postane isplativ. Zbog toga su ove metode i dalje vrlo česte u praksi“ [3].

Važno je naglasiti da phishing danas više ne izgleda kao ranije, jednostavne poruke sa očiglednim greškama. „Savremeni napadi često koriste profesionalno dizajnirane stranice koje u potpunosti imitiraju poznate servise, poput banaka, e-mail provajdera ili društvenih mreža. Ponekad napadači koriste i ranije ukradene podatke kako bi poruke djelovale što uvjerljivije i personalizovanije. Na taj način žrtva ima veće povjerenje u sadržaj poruke i lakše dolazi do greške“ [4].

Kada napadač uspije da preuzme korisnički nalog, posljedice mogu biti ozbiljne. On tada može slati poruke u ime žrtve, pristupati privatnim podacima, mijenjati informacije ili pokušati izvršiti dodatne prevare. U poslovnom okruženju to može značiti i promjenu bankovnih podataka na fakturama, preusmjeravanje plaćanja ili krađu osjetljivih poslovnih informacija.

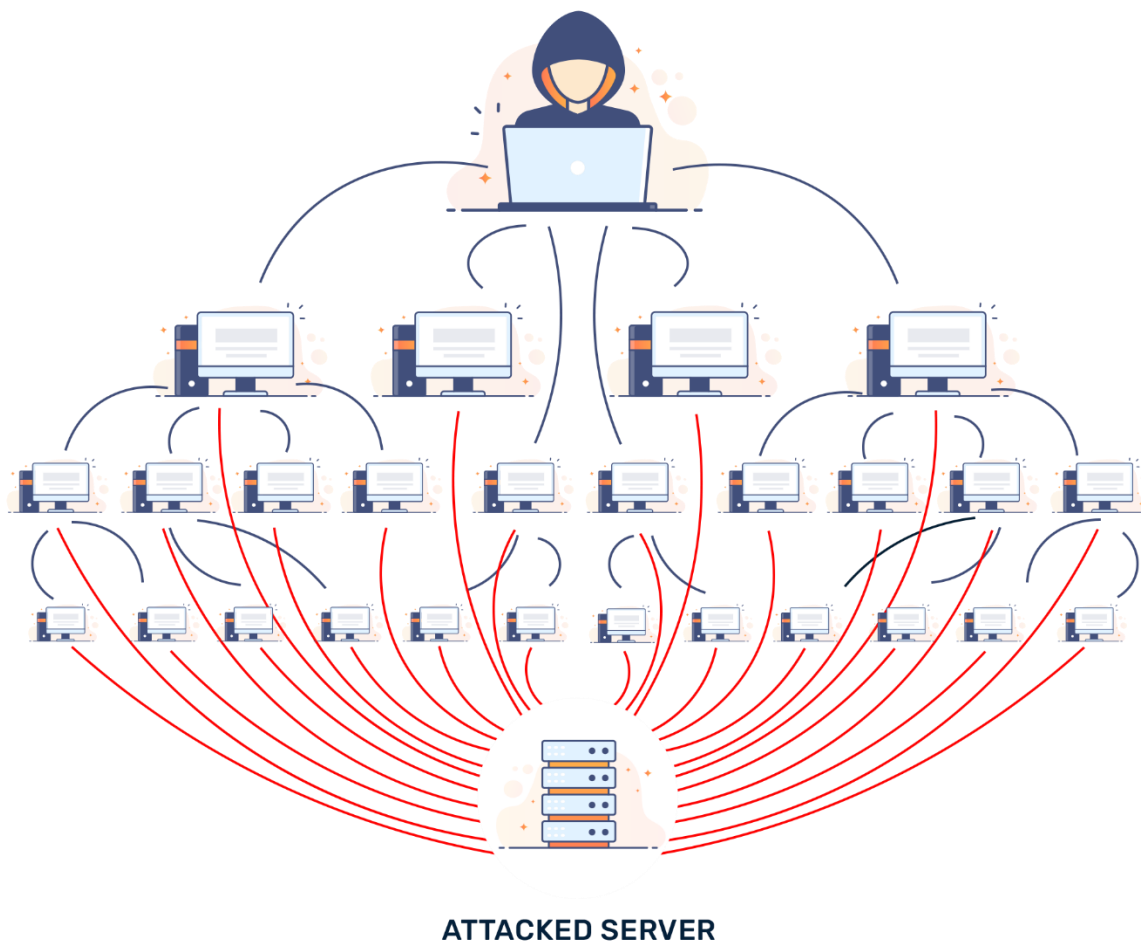
Jedan od posebno opasnih oblika jeste preuzimanje naloga, gdje napadač koristi ukradene lozinke ili pristupne tokene kako bi ušao u postojeće korisničke profile. Iako se višefaktorska autentifikacija smatra važnom zaštitom, ona nije uvijek dovoljna ako korisnik sam nesvjesno odobri pristup ili unese podatke na lažnoj stranici. Zbog toga se sve više pažnje posvećuje upravljanju identitetima, kontroli pristupa i detekciji neuobičajenog ponašanja, umjesto oslanjanja samo na lozinke.

Krađa identiteta ne završava samim pristupom nalogu. Ukoliko napadač dobije kontrolu nad korisničkim podacima, može ih dalje zloupotrebjavati za finansijske prevare, uzimanje kredita, online kupovine ili ucjene. Ukradeni identiteti se često prodaju na ilegalnim tržištima, gdje ih drugi akteri dalje koriste za različite kriminalne aktivnosti. Zbog toga se phishing i krađa identiteta

smatraju ključnim dijelom šireg lanca sajber kriminala, koji uključuje i tehničke i socijalne metode napada.

2.3. Napadi na dostupnost (botneti i DDoS)

DDoS napadi (napadi uskraćivanjem usluge) imaju jasnu svrhu, a to je da onemoguće normalan rad nekog servisa ili sistema. Za razliku od napada koji imaju cilj krađu podataka, ovdje je fokus na prekidu rada, stvaranju finansijske štete ili vršenju pritiska na organizaciju. U nekim situacijama DDoS napad se koristi kao distrakcija, dok se u pozadini odvija drugi, ozbiljniji napad. U drugim slučajevima riječ je o direktnoj ucjeni, gdje napadači traže novac kako bi zaustavili napad. „ENISA navodi da su napadi na dostupnost, uključujući DDoS, među najčešćim i najznačajnijim prijetnjama u savremenom digitalnom okruženju“ [3].

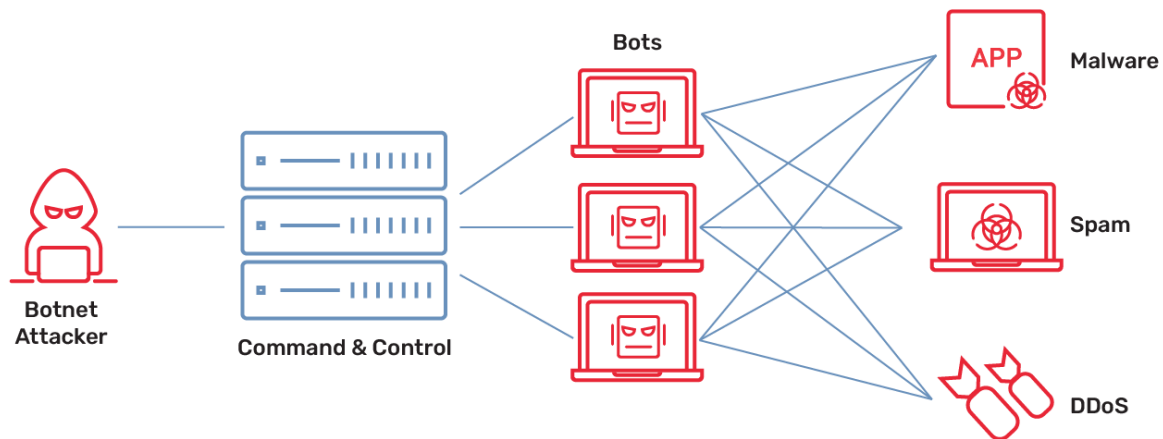


Slika 3 - Slikoviti prikaz DDoS napada na server

Botneti su mreže zaraženih uređaja koje napadači koriste da bi izveli DDoS napade. Takve mreže mogu biti veoma velike i uključivati različite uređaje, uključujući računare, rutere i pametne IoT uređaje. Problem je što vlasnici tih uređaja često ni ne znaju da su njihovi sistemi kompromitovani i da učestvuju u napadu. Kada dođe do DDoS incidenta, organizacije moraju brzo reagovati i

koristiti različite mjere zaštite, kao što su filtriranje saobraćaja, saradnja sa internet provajderima i unaprijed pripremljeni planovi reagovanja.

DDoS napadi ne uzrokuju samo tehničke probleme, već mogu izazvati i ozbiljne društvene i ekonomske posljedice. Čak i kada napadač nema direktnu finansijsku korist, prekid rada servisa može izazvati velike gubitke za organizacije i nelagodu za korisnike koji zavise od tih usluga. Zbog toga se DDoS napadi često posmatraju i kao pitanje šire otpornosti sistema, a ne samo kao izolovani tehnički incidenti.



Slika 4 - Primjer korištenja Botneta kako bi se izveo DDoS napad

„Microsoft u svom izvještaju ukazuje na to da se DDoS napadi stalno razvijaju i da napadači traže nove načine da povećaju njihov uticaj i zaobiđu zaštitne mehanizme“ [4]. U praksi, organizacije koje imaju dobro razvijene sisteme zaštite, redundansu i stalni monitoring obično imaju znatno manje posljedice, čak i kada napad nije moguće u potpunosti spriječiti.

3. SUZBIJANJE SAJBER KRIMINALA

3.1. Međunarodni pravni okvir i prekogranična saradnja

Sajber kriminal se veoma često dešava preko granica država. U jednoj situaciji napadač može biti u jednoj zemlji, serveri i infrastruktura u drugoj, dok su žrtve raspoređene širom svijeta. Zbog toga nacionalni zakoni sami po sebi nisu dovoljni za efikasno suzbijanje ovakvih djela, pa je neophodna međunarodna saradnja.

„Jedan od najvažnijih međunarodnih dokumenata u ovoj oblasti je Budimpeštanska konvencija o sajber kriminalu. Ona postavlja osnovna pravila za to koja se djela smatraju krivičnim, kako se prikupljaju elektronski dokazi i na koji način države treba da sarađuju u istragama“ [1]. Njena važnost nije samo u pravnim odredbama, već i u tome što pomaže državama da koriste slične definicije i procedure, što olakšava zajednički rad.

U praksi, jedan od najvećih problema je vrijeme. Digitalni dokazi se mogu vrlo brzo obrisati, izmijeniti ili premjestiti, a često se nalaze na serverima privatnih kompanija koje posluju u različitim državama. Klasični pravni mehanizmi međunarodne pomoći u krivičnim stvarima često traju predugo za potrebe digitalnih istraga. „Zbog toga je uveden i Drugi dodatni protokol uz Konvenciju, koji ima za cilj da ubrza saradnju i olakša pristup elektronskim podacima, posebno u hitnim slučajevima“ [2]. Time se pokušava prilagoditi pravni sistem brzini kojom funkcioniše digitalno okruženje.



Slika 5 - Europol konferencija sa glavnom temom sajber kriminala u digitalnom dobu

„Europol kroz svoje IOCTA izvještaje daje pregled savremenih trendova u sajber kriminalu i pokazuje kako se kriminalne grupe prilagođavaju pritisku policijskih i pravosudnih organa“ [2]. Ovi izvještaji su korisni jer povezuju pravni okvir sa stvarnim stanjem u praksi. Iako zakoni mogu postaviti osnovu, uspjeh istraga često zavisi od brze razmjene informacija, saradnje između država i povjerenja između institucija.

„Važan aspekt međunarodne borbe protiv sajber kriminala jeste i zaštita osnovnih ljudskih prava. Efikasna istraga ne smije dovesti do prekomjernog zadiranja u privatnost građana. Zato se u okviru Budimpeštanske konvencije posebno naglašava potreba za ravnotežom između potrebe za otkrivanjem i procesuiranjem krivičnih djela i zaštite prava na privatnost i zakonito postupanje“ [1] [2].

3.2. Digitalni dokazi i digitalna forenzika

Digitalni dokazi imaju posebna svojstva koja ih razlikuju od klasičnih dokaza. Oni se lako kopiraju, mogu se brzo izmijeniti i često ne ostavljaju vidljive tragove za osobe koje nisu stručne u toj oblasti. Zbog toga je digitalna forenzika postala veoma važna disciplina u borbi protiv sajber kriminala, ali i u drugim vrstama istraga i sporova.

Uspješna forenzička analiza zahtijeva dobro razumijevanje načina na koji sistemi funkcionišu, kako nastaju digitalni tragovi i kako se podaci mogu prikupiti na način da budu pouzdani i prihvatljivi u pravnom postupku [13]. U praksi, svaka greška može dovesti do gubitka dokaza. Na primjer, nepravilno gašenje sistema, brisanje logova ili neadekvatno kopiranje podataka može uništiti važne informacije i narušiti lanac čuvanja dokaza, poznat kao chain of custody.

Digitalna forenzika ne podrazumijeva samo tehničku analizu diskova i sistema, već i rekonstrukciju događaja. To uključuje utvrđivanje šta se tačno dogodilo, kojim redoslijedom su se događaji odvijali, ko je imao pristup sistemu i kakve su posljedice nastale. U poslovnom okruženju posebno je važno utvrditi da li je došlo do curenja podataka i koje informacije su potencijalno kompromitovane. Kod ransomware napada, na primjer, nije dovoljno samo vratiti sisteme iz rezervnih kopija, već je potrebno provjeriti da li su podaci prije toga bili izneseni, jer to značajno utiče na pravne i reputacione posljedice.

Dodatni izazov predstavlja činjenica da se digitalni dokazi često nalaze u cloud okruženjima ili na serverima koji su fizički smješteni u različitim državama. To znači da se istraga mora voditi kroz više pravnih sistema i uz saradnju različitih pružalaca usluga. „Drugi dodatni protokol uz Budimpeštansku konvenciju pokušava da olakša pristup određenim vrstama elektronskih podataka i ubrza međunarodnu saradnju, uz jasno definisane uslove i zaštitne mehanizme“ [2]. I pored toga, u praksi i dalje postoji izazov usklađivanja brzine digitalnih istraga sa pravnim procedurama.

Takođe treba napomenuti da forenzički kapaciteti nisu jednako razvijeni u svim organizacijama i državama. Mnoge manje organizacije nemaju sopstvene forenzičke timove, pa zavise od eksternih stručnjaka. Zbog toga je veoma važna prethodna priprema, koja uključuje plan reagovanja na incidente, pravilno vođenje logova i dobar pregled sistema. Organizacije koje su se unaprijed pripremile obično imaju znatno više šanse da kontrolišu incident i smanje štetu, dok one koje to nisu često ulaze u haotične i neorganizovane reakcije.

3.3. Upravljanje rizikom i organizacione mjere zaštite

Savremeni pristup sajber bezbjednosti polazi od ideje da se sajber kriminal ne može u potpunosti eliminisati, već da se njegov rizik mora kontrolisati i smanjivati. Drugim riječima, bezbjednost nije jednokratna mjera ili alat, već kontinuiran proces koji uključuje tehničke, organizacione i upravljačke aktivnosti. „NIST Cybersecurity Framework (CSF 2.0) upravo na taj način posmatra problem, jer organizacijama pomaže da razumiju kako da identifikuju rizike, zaštite sisteme, otkrivaju incidente, reaguju na njih i oporave se nakon napada“ [2].

U praksi, organizacije najčešće kombinuju različite tehničke mjere kao što su kontrola pristupa, višefaktorska autentifikacija, segmentacija mreže, redovno ažuriranje sistema, sigurnosne kopije i sistemi za nadzor. Međutim, sama postojanost ovih mjera ne znači mnogo ako se one ne primjenjuju dosljedno i ako nisu prilagođene realnim potrebama organizacije. Veliki problem u praksi je upravo nedostatak prioritizacije, jer organizacije često ne znaju koji su im najvažniji sistemi i podaci, pa resurse raspoređuju neefikasno.

„Zbog toga se u savremenim pristupima sve više naglašava upravljanje rizikom na osnovu stvarnih podataka, a ne pretpostavki. Izvještaji poput ENISA Threat Landscape i Verizon DBIR pomažu organizacijama da razumiju koje su prijetnje najčešće i kako napadači zapravo ulaze u sisteme“ [3], [5]. Na primjer, ako se pokaže da su kompromitovani nalozi i phishing najčešći ulazni vektori, onda ulaganje u MFA, obuku korisnika i kontrolu pristupa postaje prioritet. Na isti način, sve veća uloga trećih strana pokazuje da se bezbjednost ne može posmatrati samo unutar jedne organizacije, već i kroz cijeli lanac dobavljača i partnera.

„Jedan od dodatnih izazova u savremenom poslovanju jeste upravo ta međuzavisnost. Organizacije sve više koriste cloud servise, eksterne IT provajdere i različite digitalne platforme, što povećava efikasnost, ali i uvodi novi sloj rizika. Ako jedan od dobavljača bude kompromitovan, posljedice se mogu proširiti na veliki broj povezanih sistema. Zbog toga upravljanje dobavljačima postaje sastavni dio sajber bezbjednosti, a ne samo pravno ili administrativno pitanje“ [9].

3.4. Edukacija korisnika i kultura bezbjednosti

Iako se sajber bezbjednost često posmatra kroz tehnologiju, u praksi se veliki broj incidenata dešava zbog ljudskog faktora. Korisnici su često prva meta napada jer je lakše manipulirati čovjekom nego probiti tehničku zaštitu sistema. Najčešći problemi su klikovi na phishing linkove, korištenje slabih ili ponovljenih lozinki, nepažljivo otvaranje priloga i dijeljenje osjetljivih informacija.

Zbog toga edukacija korisnika ima ključnu ulogu, ali ona ne može biti jednokratna aktivnost. Ako se zaposlenima jednom godišnje održi kratko predavanje, efekat je minimalan jer se prijetnje stalno mijenjaju. Mnogo bolji pristup je kontinuirana i praktična edukacija koja uključuje realne primjere, simulacije phishing napada i jasne procedure za prijavu sumnjivih aktivnosti. Cilj nije da svi postanu IT stručnjaci, već da razviju osnovnu sposobnost prepoznavanja rizika i pravilnog reagovanja.

„Važan aspekt u ovom kontekstu je i organizaciona kultura. Ako zaposleni imaju strah da prijave grešku, incidenti se često kriju, što može dovesti do mnogo većih posljedica. Suprotno tome, organizacije koje podstiču prijavljivanje problema i brzo reagovanje obično imaju manju štetu kada do incidenta dođe. Microsoft u svojim analizama ističe da se mnogi napadi zasnivaju upravo na psihološkoj manipulaciji korisnika, zbog čega tehnička zaštita bez edukacije nije dovoljna“ [4].

Na kraju, važnu ulogu ima i rukovodstvo organizacije. Ako menadžment ne poštuje osnovna pravila bezbjednosti, teško je očekivati da će ih poštovati i ostali zaposleni. Bezbjednosna kultura se u velikoj mjeri gradi kroz primjer, a ne samo kroz formalne politike. Zbog toga se sajber bezbjednost ne može posmatrati kao tehnički problem, već kao dio organizacione discipline i svakodnevnih navika.

ZAKLJUČAK

Sajber kriminal predstavlja veoma složen i dinamičan fenomen koji se stalno razvija zajedno sa tehnologijom. Njegova specifičnost je u tome što ne obuhvata samo tehničke napade na računarske sisteme, već i širi skup aktivnosti koje uključuju psihološku manipulaciju, ekonomske motive i pravna ograničenja. U tom smislu, podjela na sajber-zavisna i sajber-omogućena krivična djela pomaže da se bolje razumije širina ovog problema. Dok prva grupa obuhvata napade koji ne mogu postojati bez računarskih sistema, druga pokazuje kako se klasični oblici kriminala značajno proširuju i ubrzavaju u digitalnom okruženju.

Savremeni razvoj sajber kriminala pokazuje i njegovu sve veću profesionalizaciju. Kriminalne grupe danas često funkcionišu kroz specijalizovane uloge i takozvane “as-a-service” modele, gdje se alati, infrastruktura i usluge mogu iznajmiti ili kupiti na ilegalnim tržištima. Ovakav pristup značajno snižava tehničku barijeru za izvršenje napada i omogućava većem broju aktera da se uključe u kriminalne aktivnosti. Zbog toga sajber kriminal postaje masovniji, organizovaniji i teži za otkrivanje.

Efikasno suzbijanje sajber kriminala zahtijeva istovremeno djelovanje na više nivoa. Pravni okvir i međunarodna saradnja imaju ključnu ulogu, jer se napadi i digitalni dokazi gotovo uvijek protežu preko granica država. U tom kontekstu, Budimpeštanska konvencija i njen Drugi dodatni protokol predstavljaju važan osnov za harmonizaciju zakonodavstva i unapređenje saradnje u prikupljanju elektronskih dokaza. Ipak, pravni okvir sam po sebi nije dovoljan bez odgovarajućih tehničkih kapaciteta i digitalne forenzike koja omogućava očuvanje, analizu i validnost dokaza.

Na organizacionom nivou, najvažniji pristup predstavlja upravljanje rizikom kroz kombinaciju tehničkih i upravljačkih mjera. To uključuje kontrolu pristupa, zaštitu identiteta, redovno ažuriranje sistema, sigurnosne kopije, monitoring i jasno definisane procedure za reagovanje na incidente. Međutim, jednako važnu ulogu ima i ljudski faktor, jer se veliki broj napada zasniva na socijalnom inženjeringu i manipulaciji korisnika. Zbog toga tehnička zaštita bez edukacije i razvijene bezbjednosne kulture nije dovoljna.

Na kraju, može se zaključiti da sajber kriminal nije problem koji se može potpuno eliminisati, već pojava koja se može kontrolisati i ograničiti. Njegovo suzbijanje zavisi od kombinacije pravnih mjera, tehničke zaštite, organizacione discipline i kontinuirane edukacije korisnika. Tek zajedničkim djelovanjem ovih elemenata moguće je smanjiti uticaj sajber kriminala i povećati ukupni nivo digitalne bezbjednosti.

POPIS SLIKA

Slika 1 - Potjernica izdata od strane FBI-a u svrhu potjere ruskih državljana koje vezuju za sajber kriminal	3
Slika 2 - Primjer Ransomware iznude u pravom životu	5
Slika 3 - Slikoviti prikaz DDoS napada na server	7
Slika 4 - Primjer korištenja Botneta kako bi se izveo DDoS napad	8
Slika 5 - Europol konferencija sa glavnom temom sajber kriminala u digitalnom dobu	9

CITATNI IZVORI

- [1] M. McGuire i S. Dowling, »Cyber crime: A review of the evidence,« Home Office, London, 2013.
- [2] United Nations Office on Drugs and Crime (UNODC), »Comprehensive Study on Cybercrime (Draft, February 2013),« UNODC, February 2013. [Mrežno]. Available: https://www.unodc.org/documents/organized-crime/UNODC_CCPCJ_EG.4_2013/CYBERCRIME_STUDY_210213.pdf.
- [3] National Institute of Standards and Technology (NIST), »The NIST Cybersecurity Framework (CSF) 2.0,« NIST, Gaithersburg, MD, 2024.
- [4] Europol, »Internet Organised Crime Threat Assessment (IOCTA) 2024,« Europol, 22 July 2024. [Mrežno]. Available: <https://www.europol.europa.eu/publication-events/main-reports/internet-organised-crime-threat-assessment-iocta-2024>.
- [5] Microsoft, »Microsoft Digital Defense Report 2024,« Microsoft, 2024. [Mrežno]. Available: <https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Microsoft%20Digital%20Defense%20Report%202024%20%281%29.pdf>.
- [6] European Union Agency for Cybersecurity (ENISA), »ENISA Threat Landscape 2024,« ENISA, 19 September 2024. [Mrežno]. Available: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>.
- [7] Verizon, »2025 Data Breach Investigations Report (DBIR),« Verizon Business Resources, 2025. [Mrežno]. Available: <https://www.verizon.com/business/resources/Tea/reports/2025-dbir-data-breach-investigations-report.pdf>.
- [8] Council of Europe, »Convention on Cybercrime (ETS No. 185),« Council of Europe (Treaty/Document repository), 23 November 2001. [Mrežno]. Available: <https://rm.coe.int/CoERMPublicCommonSearchServices/DisplayDCTMContent?documentId=0900001680080f0b>.
- [9] Council of Europe, »Second Additional Protocol to the Convention on Cybercrime on enhanced co-operation and disclosure of electronic evidence (CETS No. 224),« Council of Europe Publishing (book.coe.int), 12 May 2022. [Mrežno]. Available: <https://book.coe.int/en/texts-of-council-of-europe-treaties/11913-pdf-second-additional-protocol-to-the-convention-on-cybercrime-on-enhanced-co-operation-and-disclosure-of-electronic-evidence-cets-no-224.html>.
- [10] World Economic Forum, »Global Cybersecurity Outlook 2025 (PDF),« World Economic Forum Reports, January 2025. [Mrežno]. Available: https://reports.weforum.org/docs/WEF_Global_Cybersecurity_Outlook_2025.pdf.